Reading: Course 2 resources and citations

Module 1: Security domains

Resources

Manage common threats, risks, and vulnerabilities

- NIST RMF
- HITRUST
- cybersecurity risks
- top 10 most critical security risks
- NIST National Vulnerability Database
- CISA Known Exploited Vulnerabilities Catalog
- OWASP Top Ten
- NIST RMF

Citations

Explore the CISSP security domains, Part 1

- The International Information Systems Security Certification Consortium. (2021, May 1). CISSP certification exam outline.

Security domains cybersecurity analysts need to know

- Department of defense standard. (1982, August). Department of defense trusted computer system evaluation criteria. Department of defense standard.
- (ISC)2. (2021, May 1). CISSP Certification Exam Outline.
- National Institute of Standards and Technology. (n.d.). NIST special publication 1800-25. Executive Summary: Data Integrity. Retrieved December, 2022.
- National Institute of Standards and Technology. (n.d.). Glossary.
- National Institute of Standards and Technology Special publication 800-218. (2022). Secure software development framework (SSDF) version 1.1: Recommendations for mitigating the risk of software vulnerabilities.
- U.S. Department of Commerce. (n.d.). Information security. Osy.

Key impacts of threats, risks, and vulnerabilities

- Congressional Research Service. (2017, March 10). Dark web. CRS report.

NIST's Risk Management Framework

- National Institute of Standards and Technology. (n.d.). NIST risk management framework. Information technology laboratory: Computer security resource center. Retrieved December, 2022.

Manage common threats, risks, and vulnerabilities

- Cybersecurity & Infrastructure Security Agency. (n.d.). Assessing security risk in legacy systems. Build security in.
- Cybersecurity & Infrastructure Security Agency. (n.d.). Known exploited vulnerabilities catalog. Retrieved May, 2023.
- European Commission. (n.d.). Principles of the GDPR. Rules for business and organisations.
- Federal Bureau of Investigations. (n.d.). Ransomware. Scams and safety.
- Federal Trade Commission. (2017, June 28). Connected cars: Privacy, security issues related to connected, automated vehicles. Events.
- Homeland Security. (2022, June 8). Securing the internet of things. Publication library.
- IPSpecialist LTD. (2021). SYO-601: CompTIA security+ study guide with practice questions & labs third edition. Document control.
- National Institute of Standards and Technology. (2022, October 5). NIST risk management framework RMF. Information technology laboratory: Computer security resource center.
- National Institute of Standards and Technology. (2022, September 16). Cybersecurity risks. Cybersecurity basics.
- National Institute of Standards and Technology. (n.d.). Vulnerabilities. National vulnerability database. Retrieved May, 2023.
- Queensland Audit Office. (2022, September 27). How you can manage the risk of your legacy systems. Blog.
- The Open Web Application Security Project. (2021). A01:2021 – Broken access control. Top 10:2021 list. Retrieved December, 2022.
- The Open Web Application Security Project. (2021). A02:2021 – Cryptographic failures. Top 10:2021 list. Retrieved December, 2022.
- The Open Web Application Security Project. (2021). A07:2021 – Identification and authentication failures. Top 10:2021 list. Retrieved December, 2022.
- The Open Web Application Security Project. (2021). A03:2021 – Injection. Top 10:2021 list. Retrieved December, 2022.
- The Open Web Application Security Project. (2021). A04:2021 – Insecure design. Top 10:2021 list. Retrieved December, 2022.
- The Open Web Application Security Project. (2021). A09:2021 – Security logging and monitoring failures. Top 10:2021 list. Retrieved December, 2022.
- The Open Web Application Security Project. (2021). A05:2021 – Security misconfiguration. Top 10:2021 list. Retrieved December, 2022.
- The Open Web Application Security Project. (2021). A10:2021 – Server-side request forgery (SSRF). Top 10:2021 list. Retrieved December, 2022.
- The Open Web Application Security Project. (2021). A08:2021 – Software and data integrity failures. Top 10:2021 list. Retrieved December, 2022.
- The Open Web Application Security Project. (2021). A06:2021 – Vulnerable and outdated components. Top 10:2021 list. Retrieved December, 2022.

Module 2: Security frameworks and controls

Resources

The relationship between frameworks and controls

- Physical Access Control presentation

More about OWASP security principles

- vulnerability scanner

More about security audits

- Assessment and Auditing Resources
- IT Disaster Recovery Plan

Citations

The relationship between frameworks and controls

- Cloud Google. (n.d.). ISO/IEC 27001. Compliance.
- Health Sector Cybersecurity Coordination Center. (2019, November 14). Physical access control. Office of information security.
- National Institute of Standards and Technology. (n.d.). Glossary. Retrieved December, 2022.

Explore the CIA triad

- National Institute of Standards and Technology. (2020). Data integrity: Identifying and protecting assets against ransomware and other destructive events. NIST special publication 1800-25A. Retrieved December, 2022.

Practice: Use the CIA triad in workplace situations

- National Institute of Standards and Technology. (n.d.). Cryptography. Cybersecurity. Retrieved December, 2022.
- The Open Web Application Security Project. (2016, August 3). Security by Design Principles. OWASP wiki. Retrieved December, 2022.

NIST frameworks

- National Institute of Standards and Technology. (n.d.). Cybersecurity framework. Industry impacts. Retrieved December, 2022.
- Barrett, M. (2018, April 16). Framework for improving critical infrastructure cybersecurity. Cybersecurity framework.
- National Institute of Standards and Technology. (n.d.). Security and privacy controls for information systems and organizations. NIST Special publication 800-53, revision 5. Retrieved December, 2022.

Explore the five functions of the NIST Cybersecurity Framework

- Barrett, M. (2018, April 16). Framework for improving critical infrastructure cybersecurity. Cybersecurity framework.

OWASP security principles

- The Open Web Application Security Project. (n.d.). Architecture design. Security architecture. Retrieved December, 2022.
- The Open Web Application Security Project. (n.d.). Security by design principles. OWASP wiki. Retrieved December, 2022.
- OWASP.org. (2023). Who is the OWASP® Foundation? Retrieved May, 2023.

More about OWASP security principles

- National Institute of Standards and Technology. (n.d.). Glossary. Retrieved December, 2022.
- The Open Web Application Security Project. (2016, August 3). Security by design principles. OWASP wiki. Retrieved December, 2022.

More about security audits

- National Institute of Standards and Technology. (n.d.). Glossary. Retrieved December, 2022.
- National Institute of Standards and Technology. (n.d.). Assessment & auditing resources. Cybersecurity Framework. Retrieved December, 2022.
- Ready.gov. (2021, February, 17). IT disaster recovery plan. Ready business.

Portfolio Activity: Conduct a security audit

- Card acquiring service. (n.d.). Cas rules and security requirements.
- CDC. (2022, June 28). Health insurance portability and accountability act of 1996 (HIPAA).
- GOV.UK. (n.d.). Data protection.
- NDMB. (n.d.). SOC 1 (SSAE 16/SSAE 18) - New standards for SOC 1 reports.
- NIST. (n.d.). Cybersecurity framework. Examples of framework profiles.

Module 3: Introduction to cybersecurity tools

Citations

Logs and SIEM tools

- Google Cloud Tech. (2020). Getting started with event threat detection. Google Cloud tech.
- National Institutes of Health. (2021, July). Security information and event management (SIEM): Analysis, trends, and usage in critical infrastructures. PMC PubMed Central.

The future of SIEM tools

- National Institutes of Health. (2021, July). Security information and event management (SIEM): Analysis, trends, and usage in critical infrastructures. PMC PubMed Central.

Explore common SIEM tools

- Google Cloud. (n.d.). Chronicle security. Chronicle overview.
- Splunk. (2022, January 19). Use Splunk enterprise security. Security posture dashboard.
- Splunk. (n.d.). Why customers choose Splunk. About us.

More about cybersecurity tools

- U.S. Embassy Suva. (2021, July 28). Cybersecurity open source tools. Political/economic section.

Use SIEM tools to protect organizations

- Google Cloud. (n.d.). Chronicle overview. Product overview.
- National Institutes of Health. (2021, July). Security Information and Event Management (SIEM): Analysis, Trends, and Usage in Critical Infrastructures. PMC PubMed Central.
- Splunk. (n.d.). Security Posture dashboard. Use Splunk Enterprise Security.
- Splunk. (2022, January 19). Use Splunk enterprise security. Security posture dashboard.
- Splunk. (n.d.). Why customers choose Splunk. About us.

Module 4: Use playbooks to respond to incidents

Resources

More about playbooks

- United Kingdom, National Cyber Security Center (NCSC) - Incident Management
- Australian Government - Cyber Incident Response Plan
- Japan Computer Emergency Response Team Coordination Center (JPCERT/CC) Vulnerability Handling and related guidelines
- Government of Canada - Ransomware Playbook
- Scottish Government - Playbook Templates

Citations

More about playbooks

- Australian Government. (n.d.). Cyber incident response plan guidance. Australian cyber security centre.
- Center for Internet Security. (n.d.). Cyber incident response. Information technology standard.
- Government of Canada. (n.d.). Ransomware playbook (ITSM.00.099). Cyber security guidance.
- Japan Computer Emergency Response Team Coordination Center (JPCERT/CC). (2019, November 5). Vulnerability handling and related guidelines. Alerts & Advisories.
- National Cyber Security Centre. (n.d.). Incident management. About the NCSC.
- Scottish Government. (2021, July 21). Cyber resilience: Incident management. Publications.

Identify: Phases of an incident response playbook

- Cybersecurity & Infrastructure Security Agency. (2021, November). Cybersecurity incident & vulnerability response playbooks. TLP:White.

Practice: Respond to a SIEM alert

- Cybersecurity & Infrastructure Security Agency. (2021, November). Cybersecurity incident & vulnerability response playbooks. TLP:White.
